CECS (Risk Management Summary)

1. Project Leader – Timilsena, Kamal Raj (hdd5ps)

2. Requirements and Design Lead – Bryington, Mason Toby (xur6rh)

3. Implementation and Integration Lead - Muwanguzi, Precious Solomon (max7jn)

1. Top 5 Highest-Priority Risks

- R4: Injection Vulnerability (Technical, Score 20): Untrusted user inputs allow SQL or script injection into the database.
- R7: Requirement Volatility (Project Mgmt, Score 20): Cultural credit eligibility rules change late, forcing a redesign of core logic.
- R15: Privilege Escalation (User/Stakeholder, Score 20): Students bypass role checks to approve their own events or credits.
- R3: Map Integration Failure (Technical, Score 16): Filter or feed changes break map pin rendering.
- R6: Scope Creep on Maps (Project Mgmt, Score 16): The agreed pin-and-link map feature expands into full routing and navigation.

2. Why They Are Significant

R4 and R15 both score maximum impact because they involve student data and academic integrity. A breach or unauthorized approval cannot be undone. R7 is critical because cultural credit is the core feature of CECS; a late rule change forces rework across the entire system. R3 and R6 are significant because map work is shared between team members and any scope addition or breakage blocks integration progress for everyone.

3. How Mitigations Reduce Risk

- R4: Parameterized queries and output encoding eliminate the injection surface entirely. A sprint-end security review catches anything missed.
- R7: Storing eligibility rules as configuration means a rule change is a data update, not a code rewrite. Rules are confirmed with stakeholders before sprint 2.
- R15: Server-side role checks on every privileged endpoint, combined with audit logs, mean a crafted request cannot bypass access control even if the frontend is manipulated.
- R3: Contract tests on the map pin payload catch breaking changes in Continuous Integration before they reach production. A fallback to an external directions link keeps the feature usable if the embedded map breaks.
- R6: Scope is frozen in writing as pin plus external link. Routing requests are redirected to the backlog with a documented reason.

4. Assumptions

- Cultural credit rules are set by the institution and can change without notice.
- Server-side role validation is the team's responsibility. No framework handles it automatically.
- The map provider is a free or student-licensed tier, so paid features and high API quotas are out of scope.
- CI is set up from day one, not added mid-project.

5. Reflection (Most Surprising Risk)

R14 (Data Inconsistency from free-text tags, score 16) was the most surprising. It was easy to treat tags as a minor UI detail, but free-text input quickly produces near-duplicate tags like "career," "Career Fair," and "careers" that make filters feel broken even when the code is correct. The fix is not a code change; it is replacing the free-text field with a controlled dropdown. This was a reminder that some of the highest-impact problems in a system are not engineering failures but design decisions made too early without thinking through how real users will enter data.